

THE UNIVERSITY OF TULSA
THE GRADUATE SCHOOL

MEASURING BUSINESS EMAIL COMPROMISE ATTACKS WITH VISUALLY
IMPERSONATED DOMAIN NAMES

by
Geoffrey Thomas Simpson

A dissertation submitted in partial fulfillment of
the requirements for the degree of Doctor of Philosophy
in the Discipline of Computer Science

The Graduate School
The University of Tulsa

2023

THE UNIVERSITY OF TULSA
THE GRADUATE SCHOOL

MEASURING BUSINESS EMAIL COMPROMISE ATTACKS WITH VISUALLY
IMPERSONATED DOMAIN NAMES

by
Geoffrey Thomas Simpson

A DISSERTATION
APPROVED FOR THE DISCIPLINE OF
COMPUTER SCIENCE

By Dissertation Committee

Tyler Moore, Chair
John Hale
Mauricio Papa
Sal Aurigemma
Richard Clayton

COPYRIGHT STATEMENT

Copyright © 2023 by Geoffrey Thomas Simpson

All rights reserved. No part of this publication may be reproduced, stored in a retrieval system, or transmitted, in any form or by any means, electronic, mechanical, photocopying, recording, or otherwise, without the prior written permission of the author.

PREVIEW

ABSTRACT

Geoffrey Thomas Simpson (Doctor of Philosophy in Computer Science)

Measuring business email compromise attacks with visually impersonated domain names

Directed by Tyler Moore

128 pp., Chapter 7: Concluding Remarks

(226 words)

Business email compromise (BEC) is a large and growing threat. The use of visually impersonated domain names in these fraudulent emails is one way to make the attacks more effective. To understand the magnitude and impact of BEC fraud, we analyze data provided to us by the Federal Bureau of Investigation to construct an empirical distribution of the losses associated with BEC. Next, we investigate three distinct visual impersonation techniques that are identified as being used in support of business email compromise attacks. All three are referred to as *doppelgängers* for their visual mimicry of a legitimate URL and their malicious intent. The first is a *character doppelgänger*, in which actors use visually similar characters to register new domain names. We then cross-reference with historical registration data to identify specific malicious actors that establish domain names for fraudulent activity. In the second technique, the *third-party doppelgänger* attack, the malicious actor combines a known valid subdomain name that is associated with a third party with an existing related second level domain name to impersonate a third party service. The third identified technique, *first-party doppelgänger*, utilizes legitimate subdomain names of company domains in attacks against the organization or the organization's customers. Finally, we describe the popularity and usage of all three of these techniques longitudinally and measure the impact on victim companies.

ACKNOWLEDGEMENTS

I will forever be indebted to Dr. Tyler Moore, whose insight and vision has taught me to be a better researcher and computer scientist. I would like to express my deepest appreciation to my committee who have all shared their support and insight over the years. I could not be more thankful for my wife Rebecca, who is my foundation; for this would not be possible without her. For my parents, Tom and Suzy, who gave me everything. For my children for keeping me grounded. For my Uncles Greg Zumwalt and Bill Simpson, for sharing your love of computers with me.

TABLE OF CONTENTS

COPYRIGHT	iii
ABSTRACT	iv
ACKNOWLEDGEMENTS	v
TABLE OF CONTENTS	viii
LIST OF TABLES	xi
LIST OF FIGURES	xiii
CHAPTER 1: INTRODUCTION	1
1.1 Business Email Compromise	3
1.2 Prior Work	4
1.3 Structure and Contribution of this Thesis	11
1.3.1 <i>Thesis Statement</i>	11
1.3.2 <i>Structure and Contribution</i>	12
CHAPTER 2: EMPIRICAL ANALYSIS OF LOSSES FROM BUSINESS- EMAIL COMPROMISE	14
2.1 Dataset Description	14
2.2 Empirical Analysis of Losses	15
2.2.1 <i>Loss Distribution for Successful BEC Attacks</i>	16
2.2.2 <i>Recovery of Funds</i>	16
2.3 Does BEC Vary by Geography?	19
2.3.1 <i>What Is the Best Way to Normalize BEC Rates</i>	19
2.3.2 <i>Victims and Recipients by State</i>	22
2.3.3 <i>Does Fraud Success Vary by State?</i>	24
2.4 Concluding Remarks	24
CHAPTER 3: CHARACTER DOPPELGÄNGERS	28
3.1 Introduction and Background	28
3.2 Methodology	29
3.2.1 <i>Visual Impersonation Rules</i>	29
3.2.2 <i>Identifying Domain Names Used by Companies</i>	31
3.2.3 <i>Identifying Character Doppelgänger for Company Domain Names</i> . .	32

3.2.4	<i>The Name Server Data</i>	33
3.2.5	<i>Historical WHOIS Data</i>	33
3.3	Empirical Analysis	34
3.3.1	<i>How Many Character Doppelgängers Impersonate Each Company?</i> . .	34
3.3.2	<i>The Evolution of Attack-Infrastructure Targets</i>	35
3.3.3	<i>Comparing Hosting Infrastructure From First to Later Uses</i>	37
3.4	What can we learn from historical WHOIS?	42
3.4.1	<i>Registrants Who Register Multiple Character Doppelgängers</i>	42
3.4.2	<i>Do Companies Defensively Register Character Doppelgängers?</i>	47
3.4.3	<i>The Relationship Between Registrars and Name Servers</i>	48
3.5	Ethical Considerations	50
3.6	Conclusions	50
 CHAPTER 4: THIRD PARTY DOPPELGÄNGERS		52
4.1	Method of Identification of Third-Party Doppelgänger Attacks . . .	54
4.1.1	<i>Filtering Domain Name Components</i>	60
4.2	Identifying Domain Victims	61
4.3	Identifying Attack Victims	63
4.4	Attack Analysis, Victim Domains	65
4.4.1	<i>BestBuy Accountonline</i>	67
4.4.2	<i>Facebook</i>	69
4.4.3	<i>fbmta</i>	70
4.4.4	<i>zendesk</i>	71
4.5	Attacker Infrastructure	73
4.6	Conclusion	74
 CHAPTER 5: FIRST PARTY DOPPELGÄNGERS		76
5.1	Identification Methods	77
5.2	Common, Uncommon, and Rare subdomains	79
5.3	Victim Companies	81
5.3.1	<i>Attack Duration</i>	82
5.4	Victim Subdomains	84
5.5	Attacker Infrastructure	85
5.5.1	<i>Salesforce and Defensive Registrations</i>	88
5.6	Conclusion	90
 CHAPTER 6: LONGITUDINAL ANALYSIS OF DOPPELGÄNGER AT- TACK METHODS		91
6.1	Magnitude of Doppelgänger Attacks Over Time	92
6.2	Company Exposure Across Doppelgänger Attacks	93
6.2.1	<i>Character Doppelgängers Updated Measurements</i>	94
6.3	Shared Attacker Infrastructure	95
6.4	Continued Evidence of Recycling Domains	98
6.5	Conclusion	100

CHAPTER 7: CONCLUDING REMARKS	102
7.1 Best Practice Recommendations	104
7.2 Future Work	106
7.2.1 Continuous Monitoring	106
7.2.2 Expansion of Techniques	106
7.2.3 Expansion to Other Top Level Domains	107
BIBLIOGRAPHY	108
APPENDIX A: CHARACTER FREQUENCY COUNT OF .COM DOMAIN NAMES	118
APPENDIX B: RECURRING PATTERNS OF SUBDOMAIN USAGE IN THE .COM NAMESPACE	119
B.0.4 Internet Infrastructure	121
Third-Party Associated:	122
B.0.5 Blog/Hosting	123
B.0.6 Search Engine Optimization	124
B.0.7 Domain Re-hosting	124
B.0.8 Corporate Infrastructure	125
B.0.9 Misconfiguration	126
B.0.10 Random	127

LIST OF TABLES

1.1	Domain name cyber squatting examples for target <code>williams[.]com</code>	7
2.1	Proportion of attempted attacks that succeed in stealing money, grouped by amount attempted stolen.	18
2.2	Correlation matrix for candidate normalizing variables.	21
2.3	R^2 for various linear regressions using different independent and dependent variables.	21
2.4	Per-state victim and recipient figures, normalized by population.	27
3.1	Visual impersonation replacements considered in this paper.	31
3.2	Distribution of character doppelgängers per company.	35
3.3	Name servers with the most first-use domains.	38
3.4	Name servers with the most later-use domains.	39
3.5	Name server classification.	41
3.6	Registrants with at least 5 character doppelgängers, with registrar, time of first and last domain registration, and number of character doppelgängers registered.	44
3.7	Registrants with at least 5 character doppelgängers, with registrar, time of first and last domain registration, and number of character doppelgängers registered (continued).	45
3.8	Number of observed registrants broken down by the total number of character doppelgängers and whether or not privacy/proxy WHOIS was used.	47
3.9	Comparing registrars used by character doppelgängers and their associated name servers.	49

4.1	Attack methods identified by Area 1 and associated research	53
4.2	Top 1-25 .com domains with company names as subdomains in June 2022. . .	58
4.3	Top 26-50 .com domains with company names as subdomains in June 2022. .	59
4.4	Universal size of attacks on targeted .com domains with at least 10 attacks .	62
4.5	Top 30 victim domains per year	64
4.6	Top 100 most used subdomain name	66
4.7	Distribution of third-party doppelgängers per company.	67
4.8	BestBuy attack domains with components	68
4.9	.com registrations containing bestbuy and account	69
4.10	Facebook defensive registration domains with components	70
4.11	Sample of fbmta subdomains	71
4.12	Attacked fbmta subdomains	71
5.1	Common subdomain observation and attack rates	79
5.2	Size comparison of organizational usage of subdomain names	80
5.3	Subdomain scale categories sizes	81
5.4	Distribution of first-party doppelgängers per company.	82
5.5	Observation counts of top 25 most impersonated companies by first-party doppelgänger attacks count per year.	83
5.6	Defensive registrations demonstrating multiple conjunction usage	89
6.1	Multiple attack types against companies	91
6.2	Distribution of doppelgängers per company.	94
A.1	Character frequency count of .com domain names	119
B.1	Subdomain statistics for .com domain names	120
B.2	Top 50 users of subdomain names over the 5 year observation period	121
B.3	Top 30 second level domain users of subdomains by year	122
B.4	Ten random outlook.com subdomains	123
B.5	Search Engine Optimization subdomains	125

B.6	Domain Re-Hosting sample subdomains	125
B.7	Number of filtered rows by Year	127
B.8	Sample of misconfigured subdomain names	127
B.9	Sampling of random subdomain names of ozepa.com	128

PREVIEW

LIST OF FIGURES

2.1	Histogram of successful BEC thefts, grouped by amount stolen. The left graph shows the percentage of total incidents, while the right graph shows how much money is stolen in total.	15
2.2	Cumulative distribution functions (CDFs) of BEC losses, attempted and successful.	17
2.3	Histogram of blocked BEC thefts, grouped by amount attempted stolen. The left graph shows the percentage of total incidents, while the right graph shows how much money would have been stolen in total had the money not been recovered.	18
2.4	Heatmaps of normalized BEC fraud rates for victims (left) and recipients (right), normalized by state population.	22
2.5	Scatter plot of BEC victims per state (left, in black) and recipients per state (right, in blue).	24
3.1	rn visually compared to m, Calibri Font (top); vv visually compared to w, Calibri Font (bottom).	30
3.2	Visually impersonating domain names created over time (left), along with companies affected (right).	34
3.3	Visually impersonating domain names created over time, grouped by origin name server.	36
3.4	Name Server ingress and egress for vpweb.com	40
3.5	Name Server ingress and egress for domaincontrol.com	42
4.1	Attack domain name composition	56

4.2	Third-party doppelgänger attacks per year with conjunction type used	60
4.3	Timeline of potential malicious registrations attacking <code>Zendesk.com</code>	72
4.4	First registration nameserver usage for malicious registrations	73
5.1	First-party doppelgänger attacks created over time (left), along with compa- nies affected (right).	78
5.2	First-party doppelgänger subdomain attacks by scale and year	81
5.3	Cumulative distribution function of first-party doppelgänger attack spans . .	84
5.4	Top 20 nameservers of common subdomains per year for first-party dop- pelgänger attacks	86
5.5	Top 20 nameservers of uncommon subdomains per year for first-party dop- pelgänger attacks	87
5.6	Top 20 nameservers of rare subdomains per year for first-party doppelgänger attacks	88
6.1	Doppelgänger attacks per year	93
6.2	Character doppelgänger attacks per year	95
6.3	Combined top 20 nameserver usage across all doppelgänger attacks	96
6.4	Malicious registrations observed for <code>vpweb.com</code> and <code>rookdns.com</code>	97
6.5	Top 50 follow-on nameservers used by attack type	98
6.6	Top 50 first-use nameservers used by attack type	99
6.7	Name server classifications for all attacks	100
7.1	Title screen of URLCrazy application	105

CHAPTER 1

INTRODUCTION

The problem with reading is that we have to use our eyes. Somewhere in between the glowing light of the pixels on the screen and the neurons in our brain that interpret those colors into letters and words and sentences and email addresses and phone numbers and URLs and everything else is where we get fooled. It is not easy, as the methods of such trickery change over time. We train people to spot a specific trick, like watching for a ball being placed under a cup, but then the magician moves the ball with sleight of hand that the audience is forced to miss, and the malicious actor changes an i to an l in a URL and has now stolen someone’s banking credentials. The best tricks are when we see what we expect to see, and do not notice until it is too late that the trick was on us the whole time. The worst tricks are the ones ones where harm is done.

This dissertation investigates such visual tricks in service of business email compromise (BEC) attacks. We refer to those tricks as doppelgängers, because they are visually similar to a legitimate domain name, and yet they have a malicious purpose [16]. Data from the United States Federal Bureau of Investigation shows that BEC is an already large and growing problem. On May 4, 2022, the FBI released alert number I-050422-PSA that states that “Between July 2019 and December 2021, there was a 65% increase in identified global exposed losses” [29]. The total losses between that time frame is estimated at more than \$43 billion USD for combined domestic and international BEC fraud. Despite being a massive threat, we know very little about which organizations are targeted and how that has changed over time. Our focus is on the various methods these malicious actors use to create domain names that look legitimate, but are slightly different and mean to fool us. If we can identify the most efficient ways of creating these attacks, then we can protect against them better.

We identify and detect three doppelgänger methods used in malicious domain name registrations. We classify them as character doppelgängers, third-party doppelgängers, and first-party doppelgängers. A character doppelgänger, discussed in Chapter 3, is when a character or characters of a legitimate domain name is replaced with a visually similar character or characters to form a new domain name that is visually similar to the legitimate domain name. When a domain name is generated from a combination of a related third party name used in a subdomain name of a well known service provider it is a third party doppelgänger (presented in Chapter 4). The third method, a first-party doppelgänger, described in Chapter 5, is when a new domain name is generated from a combination of a legitimate first-party subdomain name of a domain name and the domain name itself, forming a new domain name that is visually similar to a legitimate URL.

We believe malicious actors are using these various identifiable techniques when registering domain names to target specific organizations. Based on general data from the FBI and other organizations monitoring malicious online activity, we have identified domain names being used for malicious purposes. We have seen it creep into the general public information with the Burisma attack using techniques that Forbes reported on in 2020 where Russian hackers registered and successfully used the site `cubenergy-my-sharepoint.com`, a third party doppelgänger, against the legitimate site `cubenergy.my-sharepoint.com` [67]. In order to understand the magnitude of financial impact that these malicious registrations have, we analyze actual case information from the FBI to detect trends in BEC fraud.

Malicious actors use various methods such as character doppelgängers, third-party doppelgängers, and first-party doppelgängers to maximize their potential effectiveness in duping victims. We can use the same techniques to identify these potentially malicious domain registrations and identify those that could be actively being used for fraud. What unites the three techniques is that they all use a form of visual impersonation in the process of creating a new second level `.com` domain name that looks as believable or close to a legitimate URL as possible. What differentiates them is the specific technique they use to

generate a visual impersonation, or doppelgänger.

1.1 Business Email Compromise

We are compelled to provide a definition of Business Email Compromise because of the confusing combination of the specificity of the phrase and the generality of the various methods that are classified as such. The Federal Bureau of Investigation first mentioned the phrase *Business E-mail Compromise* in 2014 in the Internet Crime Complaint Center’s annual report [69].

The initial definition they provide points to a specific type of fraud “The Business E-mail Compromise is a sophisticated scam targeting businesses working with foreign suppliers and/or businesses which regularly perform wire transfer payments.” From this definition, we clearly see the roots of the phrase, since they use it to describe a specific type of fraud that involves wire transfers between businesses, but it still does not represent the exact methods other than applying the adjective *sophisticated*. They go on to describe the evolution of the scam from the first reports of BEC in 2013.

Expansion of fraud within the umbrella of BEC was already being reported as being associated with other online criminal activities such as romance, lottery, employment, check scams, and vacation/rental scams as soon as 2015. In alert I-012215-PSA [24], the FBI notes that allowance of consumer-focused financial fraud within the context of the phrase from its inception causes it to be a generic place-holder for all financial fraud involving spoofing or hacking based on transactional communication. In alert I-091019-PSA [26] from 2019, the FBI expanded the BEC definition to include both businesses and individuals, noting that individuals need to take precautions against BEC scams just as businesses do.

Monetary gain was the initial focus of the fraud, but data can be a valuable target for malicious actors as well. The same impersonation techniques are also used in attempted thefts of Personal Identifiable Information of employees. In alert I-022118-PSA [25], the FBI announces that BEC fraud has been used to target employees’ personal wage and tax

statements (W-2) forms. And while the target of the fraud may change, the communication method may change as well. While the name itself includes Email as the communication platform, the phrase now also encompasses fraud attempted via any form of electronic communication. In alert I-021622-PSA [30], the FBI warns of BEC fraud taking place on any platform in which a transfer of communication happens, like via audio, video conferencing, screen sharing, and webinars.

The focus of our research is on the visual impersonation of domain names. This impersonation is referred to as *spoofing* in some contexts, and we use the phrases interchangeably. We associate the usage of *spoofed* domains as a direct measurement of BEC activity due to the identification of these types of methods by the FBI in fraudulent activity [28]. They identify three specific methods associated with BEC and spoofing: 1) Spoofed Email account 2) Spoofed Website 3) Spear phishing. They directly warn users “scammers use slight differences to trick your eye and gain your trust.”

We conclude our discussion about the evolution of the types of fraud associated with the phrase Business Email Compromise by proposing a more general description that encompasses the methods and fraud up to this point. Business Email Compromise refers to financial and/or information fraud using intentionally deceiving techniques via transactional electronic communication.

The consequences of the expansion of the umbrella of activities that fall within the purview of Business Email Compromise is that any attempts to measure it via a specific communication mechanism or platform will always be insufficient. By demonstrating the proliferation of fraudulent activities across any available electronic communication medium, we posit that to best measure and continuously monitor BEC activity, we need to measure the underlying foundational Internet technology that the malicious actors are utilizing.

1.2 Prior Work

BEC is a specialized form of cybercrime in which attackers target employees with

authority to transfer company funds and dupe them into sending money. BEC fraud has been increasing in popularity, in large part due to the large sums that can be stolen from each victim compared to consumer-targeted phishing. Mimecast reported a growth rate of 80% quarter over quarter [48]. The United States Federal Bureau of Investigation (FBI) has been involved in investigating business email compromise fraud since at least 2013 [70] and has been collecting data along the way. In 2018, the FBI reported that \$1.3 billion was successfully stolen in BEC scams [71]. And this is despite a recent global sweep in which the FBI arrested 74 people around the world perpetrating BEC fraud. The FBI reported that in 2019 BEC losses increased to \$1.7 billion [72] and \$2.7 billion in 2022 [73].

Despite these alarming figures, much remains unknown, such as about the distribution of losses, whether certain companies (based on geography or business type) are targeted more often, and whether there is any relationship between the amount attempted stolen and criminal success. In Chapter 2, we set to answer these and other questions, using data on all BEC incidents reported to the FBI’s Internet Crime Complaint Center (IC3) during nine months in 2017.

Our work is motivated by the economics of information security literature [6]. This community has shed much light on how attackers operate [54, 75, 43, 41, 40] and the effectiveness of defenses [51, 52, 42, 47].

One lingering challenge, however, has been to obtain accurate empirical measurements of losses associated with various cybercriminal activities. Estimates for aggregate losses have sometimes been tabulated (see, e.g., [5, 4]). While helpful, in order to be able to manage cybersecurity risks, it is also necessary to determine the *distribution* of loss amounts. Distributions of cybercrime losses matter for two principal reasons. First, it is widely known that the distributions of losses can be skewed, rendering mean and median values unreliable for capturing the magnitude of risk present [31]. Second, models of cybersecurity investment, including the canonical Gordon-Loeb model [33], require a loss distribution function to operate. However, due to the difficulty of obtaining empirically-validated loss distributions,

these models typically assume loss distributions selected for mathematical convenience and without regard to how much they correspond to actual losses.

In theory, insurers are in a good position to estimate loss distributions using claims data from cyber insurance products. In practice, however, actuarial data is proprietary and fiercely guarded, so there has been no public reporting of empirically-derived cyber loss distributions by insurers. Furthermore, claims data would only cover the losses paid out by insurers. This leaves out the tails of the distribution: incidents whose cost falls below the deductible or exceeds coverage limits. Given that cyber loss distributions are likely heavy-tailed, these are critical omissions. One recent approach has been to estimate loss distributions from publicly reported prices filed with state Insurance commissioners [77]. While promising, it does not eliminate the need for empirically-derived loss distributions.

Consequently, one contribution of this dissertation is to provide an empirical loss distribution for BEC losses reported to the FBI IC3. It is hoped that this can be used by researchers to validate theoretical models and by practitioners to manage BEC risks in their own organizations.

Although there is a widespread perception that phishing (the collection of credentials by means of impersonated websites) uses character doppelgängers, as seen in Table 1.1, this is far from the case. In 2006, McFedries, in an article mainly concerned with the etymology of the phishing jargon mentions replacing ‘L’ by ‘1’ and ‘O’ with zero, which he calls “homograph spoofing” [45]. However, the Anti-Phishing Working Group has been publishing summaries of phishing activity since January 2004 and even in the earliest days the main attack vector in which new domains are used was so-called ‘cousin’ domains (such as `bankname-usa.com`) [7]. So although character doppelgängers clearly were used they were not especially prevalent. More recent work has found that cousin domains have continued to be registered [68].

Krammer, also in 2006, discusses a wide range of URL obfuscation techniques applicable to phishing, including what he calls “single-script spoofing”, where he mentions ‘O’

Table 1.1: Domain name cyber squatting examples for target `williams[.]com`

Category	Sample	Reference
Character Doppelgänger	williarns.com	Chapter 3,[65]
Third-Party Doppelgänger	williams-sharepoint.com	Chapter 4
First-Party Doppelgänger	mail-williams.com	Chapter 5
Levelsquatting	www.williams.com.anotherdomain.com	[21][60]
Typo-Squatting : character removal	wiliams.com	[76][22]
Typo-Squatting : character swap	wililams.com	[76][22][65]
Typo-Squatting : character duplication	willliams.com	[76][22]
Soundsquatting	willyams.com	[56]
Combo-Squatting	williams-login.com	[38]
Bitsquatting	whlliams.com	[20][57]
Domain-Squatting	williams.new	[58]

and zero, ‘RN’ and ‘M’ and ‘L’ and ‘T’ [39]. We do not consider the L/T option in this paper. He also discusses a range of attacks using non-ASCII (IDN) characters, whilst noting that none had been reported thus far.

Gabrilovich and Gontmakher discussed what they called “homograph attacks” in 2002, explaining how Cyrillic and Greek letters that are identical (in most fonts) to ASCII characters could be used to create character doppelgängers [32]. They give an actual example, mimicking `microsoft.com`, but almost all registries (including `.com`) now rule out the mixing of character sets that this requires. In 2019 Quinkert et al. found around 3 000 homograph domains where Unicode glyphs had replaced ASCII characters [59]. They don’t provide numbers, but it is clear that a lot of examples they found involve accented characters which the registries do allow to be mixed in with normal ASCII.

As an aside, we note that the use of the term homograph is potentially confusing. Some of the literature carefully uses the term to mean single characters that are ‘homographs’ of each other, but other papers expand the term to the whole domain which is said to be a homograph of another (character doppelgänger) domain. Other authors use homoglyph for identical looking characters, but this word has yet to make it into the Oxford English Dictionary. The confusion arises because homograph is a well-known philological term for a word with the same spelling as another but a different origin and meaning (e.g. minute – 60 seconds, or very small). In the case of a homograph attack using a character

doppelgänger the whole point is that the spelling is different!

A completely different type of malicious domain name registration is typosquatting, where domains are registered in the hope that ‘fat fingered’ typists will visit a website. In 2003 Edelman documented how a particular actor had registered 8 800 domains providing sexual content on typosquatted versions of well-known domains [22]. In 2006 Banerjee et al. measured the overall prevalence of the issue [8] and in 2010 Moore and Edelman showed that the choice of domains to typosquat was not to do with the typing difficulty, but the value of the adverts that could be served from the landing pages [55]. In 2017 Szurdi and Christin investigated email typosquatting, finding that if they registered typosquatting domains they would receive a small amount of misdirected email, however they concluded that this was not actually being used for attacks at that time [64].

In 2011 Dinaburg described ‘bitsquatting’ where hardware errors cause bits to ‘flip’ between 1 and 0 within domain names [20]. His Black Hat talk clearly caught the attention of criminals because in 2013 Nikiforakis et al. showed that this had caused a spike in relevant domain registrations [57]. None of the transliterations we consider could be caused by bit flips.

The previous work we have described so far is generally concerned with attacks against a relatively small number of targets (banks, mailbox providers, cryptocurrency exchanges and major brands) although Szurdi et al. did find typosquatting attacks against a ‘long tail’ of far less important domains [65]. Their definition of typosquatting considers all single character changes so it includes bitsquatting and also some of our doppelgänger generation methods (though they discuss neither). Their study period (Oct 2012 to Feb 2014) is when we see doppelgängers just starting to rise in popularity – so our results will go some way to explaining theirs. Their definition of typosquatting is very specific in that domains are “registered to benefit from traffic intended for a target domain”. Our doppelgängers could fit the definition of typosquatting, but because the attack vector is not via user input, we consider them separate research subjects.

As we have explained, we link the use of character doppelgängers to BEC attacks and particularly to scams in which invoice payments are redirected to the criminal following an email correspondence where the victim sees a character doppelgänger and believes that the interaction is genuine. Cross and Gillett provide a survey of the literature on all types of BEC fraud and highlight many gaps in our understanding of why it works so well and how to counter it [17]. Loss figures for BEC that have been reported to them are collated by the FBI – but of course this is only a subset of actual losses worldwide [27].

We identify over a quarter of a million domains used by medium and large companies within the .com registry. We find that for around 7% of these companies very similar domain names have been registered with character changes that are intended to be indistinguishable at a casual glance. These domains would be suitable for use in BEC frauds. Using historical registration and name server data we identify the timing, rate, and movement of these look-alike domains over a ten year period. This allows us to identify clusters of registrations which are quite clearly malicious and show how the criminals have moved their activity over time in response to countermeasures. Although the malicious activity peaked in 2016, there is still sufficient ongoing activity to cause concern.

While we are focusing our research on visual impersonations, Nikiforakis et al. are researching attacks known as ‘soundsquatting’, or attacking end users who are using text to speech software and the attack domains are homophones of the legitimate domains [56]. They show how sound-dependant users are particularly vulnerable to this type of attack because there is virtually no protection against it.

We refer to malicious visual impersonations as doppelgängers because of the negative or evil connotation that the word historically has had [16]. This type of visual trickery is not limited to text based interfaces like email. Malisa et al. found malicious actors mimicking entire user interfaces of Android applications [44]. Some of these types of attacks could be piggybacked onto a malicious second level domain name within a text based user interface, such as email, to make them seem more legitimate. Visual trickery is being used by media

outlets in various forms to create narratives that may not correctly align with the data itself found Mehta and Guzmán in 2018 [46].

Quinkert et. al recognize the importance of researching visual impersonations of domain names, and they specifically look at how actors include other second level domain names as part of a subdomain of an existing second level domain [60]. Their research expands on the introduction of levelsquatting by Du et al., which embeds a legitimate looking URL within the subdomain of a different domain [21]. For example, `www.williams.com.anotherdomain.com` from Table 1.1 where the legitimate URL `www.williams.com` is embedded under the domain `anotherdomain` in the `.com` TLD. Opportunities arise for visual trickery when these URLs are viewed on devices with smaller screens, and the right part of a long URL may extend beyond the visual display of a text box, thereby hiding the malicious component of the URL. This attack uses a known good URL, similar to the doppelgänger attacks, but it combines it with a malicious URL, so the visual impersonation component is degraded when the full URL is viewed. This differentiates this attack from being a true doppelgänger, but the visual impersonation goal of the attacker is the same.

In 2019, Chiba et. al described a system called DomainScouter that calculates a score to measure the level of visual impersonation potential that a domain name may have [13]. They research a much broader range of domain names and do not limit their search to the `.com` top level domain. In order to visually assess the similarity of a prospect homograph attack domain, they generate an image that contains the legitimate domain name as a string in the image. They then do an image comparison assisted by machine learning algorithms to rank the strength an associated domain of being a visual impersonation. Sern and David suggest a similarly motivated image processing comparison named TypoSwepe [37]. It also relies on machine learning to compare images created containing strings of the domain names.

The work of Hasegawa et al. does not discuss specific visual domain impersonation

schemes, but the general difficulty that non-native English speakers have in identifying phishing emails [35]. We do not want to understate the challenge of the English language in general, and their research demonstrates that there are large numbers of users whose challenge is language in addition to spotting visual impersonations. Because all languages live on the Internet, there is concern for homograph confusion in International Domain Names. Ahmad and Erdodi iterate the various usages of Arabic characters as homographs in International Domain Names and the seriousness of the issue [3]. They make recommendations to the registration rules for domain names that could reduce the potential for these homographic attacks using these specific methods, including allowing only a single script (like English + Cyrillic) and input locale (keyboard input profiles) per domain name.

Doppelgängers are focused on the third party registration of new domain names, but in a different type of subdomain attack, malicious actors aim to host malicious content on a legitimate subdomain of a victim domain. These types of subdomain specific attacks are shown to exist by Squarcina et al. in 2021 [62]. In their research, they show how malicious actors could attack a related-domain and then host a subdomain on the same second level top level domain. The attacks in this case are dangerous because from an end user perspective, the URL looks to be legitimate, with no visual impersonation tactics employed. While they are not researching visual impersonation, they do recognize the importance of the subdomain in the use of business email compromise. Reynolds et al. show that despite end users having 96% of participants report confidence in their ability to read and parse a URL, they only found 40% of obfuscated URLs [61].

1.3 Structure and Contribution of this Thesis

1.3.1 Thesis Statement

We devise methods to identify and measure the prevalence of three visual impersonation techniques attackers use to create attack domain names for the purpose of BEC